

华中科技大学

# 课程实验报告

课程名称： 计算机系统基础

实验名称： 缓冲区溢出攻击

院 系： 计算机科学与技术

专业班级： 创新 202401

学 号：

姓 名：

指导教师：

     年      月      日

## 一、实验目的与要求

通过分析一个程序（称为“缓冲区炸弹”）的构成和运行逻辑，加深对理论课中关于程序的机器级表示、函数调用规则、栈结构等方面知识点的理解，增强反汇编、跟踪、分析、调试等能力，加深对缓冲区溢出攻击原理、方法与防范等方面知识的理解和掌握；

实验环境：Ubuntu, GCC, GDB 等

## 二、实验内容

**任务** 缓冲区溢出攻击

程序运行过程中，需要输入特定的字符串，使得程序达到期望的运行效果。

对一个可执行程序“bufbomb”实施一系列缓冲区溢出攻击(buffer overflow attacks)，也就是设法通过造成缓冲区溢出来改变该程序的运行内存映像(例如将专门设计的字节序列插入到栈中特定内存位置)和行为，以实现实验预定的目标。bufbomb 目标程序在运行时使用函数 getbuf 读入一个字符串。根据不同的任务，学生生成相应的攻击字符串。

实验中需要针对目标可执行程序 bufbomb, 分别完成多个难度递增的缓冲区溢出攻击(完成的顺序没有固定要求)。按从易到难的顺序，这些难度级分别命名为 smoke (level 1)、fizz (level 2)。

### 1、第 1 级 smoke

正常情况下，getbuf 函数运行结束，执行最后的 ret 指令时，将取出保存于栈帧中的返回（断点）地址并跳转至它继续执行（test 函数中调用 getbuf 处）。要求将返回地址的值改为本级别实验的目标 smoke 函数的首条指令的地址，getbuf 函数返回时，跳转到 smoke 函数执行，即达到了实验的目标。

### 2、第 2 级 fizz

要求 getbuf 函数运行结束后，转到 fizz 函数处执行。与 smoke 的差别是，fizz 函数有一个参数。fizz 函数中比较了参数 val 与 全局变量 cookie 的值，只有两者相同（要正确打印 val）才能达到目标。

## 三、实验记录及问题回答

### （1）实验任务的实验记录

### （2）缓冲区溢出攻击中字符串产生的方法描述

**要求：**一定要画出栈帧结构（包括断点的存放位置，保存 ebp 的位置，局部变量的位置等等）

## 四、体会

